

Security

Security & Risk Specification

This document details the security model, risk assumptions, access control guarantees, emergency procedures, and architectural invariants of UnifyVault V2.

1. Access Control Model

Access control across all protocol contracts is implemented using OpenZeppelin `AccessControl`.

Security Guarantees

- **Strict Role Isolation**: Functions restricted to `CONTROLLER_ROLE` (such as `UVBEV2.mint`, `UVBEV2.burn`, `CustodyVault.withdrawAsset`, and `CostBasisManagerV2.recordDeposit/recordRedeem`) cannot be called by arbitrary users or administrative roles without explicit authorization.
- **Arbitrator Segregation**: `P2PEscrowV2.resolveDispute` is restricted exclusively to accounts holding `ARBITRATOR_ROLE` or `GOVERNANCE_ROLE`.
- **Zero Address Validation**: All constructor and setter arguments check against `address(0)` via `AddressValidationLib.validateNonZeroAddress`.
- **Contract Code Validation**: Module setters check `address.code.length > 0` to prevent non-contract account registration.

2. Emergency Controls & Pausable Logic

Contracts subject to operational risk (`UnifyVaultController`, `CustodyVault`, `Treasury`, `UVBEV2`, `P2PEscrowV2`, `Marketplace`) inherit OpenZeppelin `Pausable`.

2.1 Emergency Circuit Breakers

- **Pause Trigger**: Accounts possessing the `GUARDIAN_ROLE` or `GOVERNANCE_ROLE` can invoke `pause()` to halt deposits, redemptions, rebalances, and escrow operations immediately upon detecting anomalous activity.
- **Resume Trigger**: `unpause()` can be invoked by `GUARDIAN_ROLE` or `GOVERNANCE_ROLE` to resume normal protocol operations.

2.2 Pausable Function Matrix

- **Contract**: Function | Paused Behavior
- `UnifyVaultController`: `deposit` | Reverts with `EnforcedPause()`
- `UnifyVaultController`: `redeem` | Reverts with `EnforcedPause()`
- `UnifyVaultController`: `rebalancePortfolio` | Reverts with `EnforcedPause()`
- `CustodyVault`: `depositAsset` | Reverts with `EnforcedPause()`
- `CustodyVault`: `withdrawAsset` | Reverts with `EnforcedPause()`
- `UVBEV2`: `_update` (transfers/mints/burns) | Reverts with `EnforcedPause()`
- `P2PEscrowV2`: `createTrade`, `fundTrade` | Reverts with `EnforcedPause()`
- `Marketplace`: `createBuyOrder`, `matchOrders` | Reverts with `EnforcedPause()`

3. Threat Model & Invariants

3.1 Inflation Attack & Donation Immunity

- **Attack Vector**: In first-deposit vault implementations, an attacker can donate collateral directly to the vault to inflate share prices and cause division-by-zero rounding loss for subsequent depositors.
- **UnifyVault Mitigation**:
 1. `CustodyVault` maintains internal accounting (`_internalBalances[asset]`) that only increments on explicit `depositAsset` calls. Direct token transfers increment `surplusAssets` but do not affect vault net asset value calculations.
 2. First deposit explicitly mints and permanently locks `DEAD_SHARES` (`1000` wei) to anchor share pricing.

3.2 On-Chain Cost Basis Conservation & Escrow Isolation

- **Locked Pre-Transfer Hook**: `UVBEV2.update()` invokes `CostBasisManagerV2.onTokenTransfer()` before balances mutate. If accounting fails, the entire transaction reverts.
- **Basis Conservation**: On ordinary peer-to-peer transfers, proportional basis moves from sender to receiver, conserving total protocol basis.
- **Escrow Isolation**: When tokens transfer to or from registered escrow contracts (`_isEscrow[from] || _isEscrow[to]`), the hook returns immediately, ensuring secondary fiat trades do not contaminate portfolio investment basis or vault valuation.

3.3 P2P Escrow Security Invariants

- **Reentrancy Immunity**: All mutating state transitions in `P2PEscrowV2` and `Marketplace` use OpenZeppelin `ReentrancyGuard` (`nonReentrant`).
- **Checks-Effects-Interactions (CEI)**: State is transitioned to `RELEASED` or `REFUNDED` before external token transfers.
- **Replay Protection**: `_usedPaymentReferences` and `_usedEvidenceHashes` mappings prevent re-using bank UTRs or receipt hashes.
- **Fee-on-Transfer Protection**: Pre- and post-transfer balances are checked during funding; transfers that deliver fewer tokens than declared revert immediately.
- **Seller Protection**: When payment is submitted, only the buyer can voluntarily forfeit and trigger refund. Sellers must raise a dispute if fiat was not received.

3.4 Oracle Resilience & Staleness Guard

- `OracleManager` enforces heartbeat window validation (`block.timestamp - updatedAt <= heartbeat`), non-zero price checks, and supports secondary fallback oracle providers.
- Swaps executed by `SwapAdapter` enforce guaranteed minimum output bounds adjusted by `swapSlippageBps` (default: `100` BPS = `1%`).

—

4. Upgradeability Assumptions

- **Immutable Core Contracts**: Core contracts (`UnifyVaultController`, `CustodyVault`, `Treasury`, `UVBEV2`) are **non-upgradeable proxy-free contracts**.
- **Dynamic Module Replacement**: Upgrades are achieved via proxy-less modular replacement: deploying a new module contract and updating its target address in `ProtocolDirectory`.
- **One-Way Registry Freeze**: `ProtocolDirectory` can be permanently frozen via `freeze()`, revoking the ability to update module addresses forever.